Evaluating Authorization Regimes and Runtime Guardrail Configurations for Tool-Using LLM Agents

Abstract

Runtime guardrails for tool-using language-model agents must distinguish authorization, execution, and task completion. We evaluate authorization semantics and security–utility trade-offs after correcting an oracle monitor that compared complete action arguments against partial target annotations. Historical labels are retained without reinterpreting isolation rejections or failures as executed harmful effects.

A corrected DeepSeek Pro study comprises 900 authorization assignments over 180 fixed cases. Both runtime configurations use ordinary prompts. AgentDojo benign-tool completion rises from 2/30 under compiled authorization to 13/30 under exact-target policy and 11/30 under exact-target full modules. The corresponding M3-v2 differences are small and uncertain. Zero security events across 490 attack assignments do not establish effectiveness because this study has no unguarded control.

A separate 480-assignment contemporaneous calibration supplies that control. On AgentDojo, policy and full modules reduce benign completion from 17/30 to 2/30, a paired difference of −50 percentage points (95% CI −66.83 to −26.80). Security results change from 3/30 to 0/30, but the paired interval includes zero. M3-v2 controls are already at zero. Sixteen synthetic Pro/Flash runs verify bounded private-data and missing-classification behavior, not general end-to-end protection. Missing outcomes and failures remain explicit.

The findings support measurement correction and disclosure of authorization burden, not full-module superiority. Oracle assistance, overlapping cohorts, adapted baselines, sparse security events, and incomplete independent-model validation limit generalization.

Keywords: prompt injection; LLM agents; runtime authorization; provenance; security–utility trade-off

1 Introduction

1.1 Motivation

Tool-using language-model agents turn generated text into actions. An indirect prompt injection embedded in a message, document, webpage, memory item, or tool response can therefore become a request to send data, modify state, or invoke a privileged operation. Public environments such as AgentDojo and InjecAgent show that security must be evaluated together with task utility rather than as a text-classification problem alone [1, 2]. Runtime systems including VIGIL, DRIFT, the Task Shield, IPIGuard, and AgentSpec consequently interpose verification, task alignment, dependency, information-flow, or policy checks before an effect is committed [3–7].

This literature also makes a broad novelty claim untenable. Verify-before-commit, contextual policy generation, least privilege, planned dependency checks, and control/data-flow separation are already occupied design spaces [3, 7–10]. Recent preprints go further by auditing context influence, comparing an authorization graph with a parameter-source execution graph, or controlling source authority in next-action decisions [11–13]. Evidence-backed permission graphs with formal runtime authorization further narrow the mechanism claim boundary [14]. The open question for this study is therefore not whether a provenance-aware guard can be built for the first time. It is whether authorization information, enforcement structure, and failure handling materially change the security and utility measured for tool-using agents.

1.2 Evaluation gap

Three distinctions are easy to blur in an agent-security experiment.

First, a detector score or model refusal is not an executed-effect endpoint. Prompt-level structuring, spotlighting, instruction hierarchy, and injection detection can reduce model compliance, but they do not by themselves prove that an unauthorized action failed to cross an external runtime boundary [15–18].

Second, the authorization regime is part of the treatment. A guard that sees per-sample answer keys, evaluator labels, or an exact policy reconstructed from the expected answer is solving a different problem from a guard that receives only trusted user intent and a non-oracle policy compiled before execution. The present source audit does not establish that such leakage is universal, so we frame this as authorization uncertainty rather than a domain-wide answer-key defect.

Third, low attack success can be purchased by blocking useful work. A runtime defense must therefore report benchmark-specific security judgments, observed simulated effects, benign completion, confirmation requests, failures, and runtime burden under an explicit intention-to-treat denominator. Unknown outcomes are not safe zeros, and task completion can precede a subsequent failure. Static attacks are also insufficient for a robustness claim when an attacker can adapt to the public defense interface [19].

1.3 Research questions

The corrected evaluation addresses three questions. The earlier six-question factorial, source-swap, replication, and adaptive program is retained as historical evidence, not retrospectively relabelled as corrected execution.

1. **RQ1: Authorization semantics.** How does target-scoped oracle authorization, rather than complete-argument equality, change completion relative to authorization compiled from trusted intent?
2. **RQ2: Security, utility, and runtime burden.** Under ordinary prompts, what security judgments, benign completion, unknown outcomes, and confirmation/blocking burden occur with no research Guard, policy modules, full modules, and the explicitly configured structural comparator?
3. **RQ3: Component evidence and applicability.** What do controlled sensitive-data and missing-classification cases establish about component behavior, and what remains unsupported on natural tasks, other models, dynamic environments, and adaptive attacks?

1.4 Study design

M3 produces three runtime decisions: ALLOW permits a proposed action, ASK waits for independent confirmation, and DENY blocks it. The automatic path may restrict, but not expand, privileges. Runtime projections keep raw answers and evaluator labels outside the model input. An exact-target oracle nevertheless supplies answer-derived authorization to the Guard; excluding raw answers does not make that condition non-oracle.

The 900-assignment corrected authorization study uses 180 fixed cases and ordinary prompts in both policy and full conditions. Four primary conditions cross the module bundle with `auto_compiled` and `exact_target_v2`; a nested subset adds broad, underspecified, and conflicting policies. A separate 480-assignment contemporaneous calibration uses 120 fixed cases, split evenly between benchmarks and between attacks and benign tool tasks. It compares no research Guard, policy, full, and a source-pinned VIGIL adaptation with model-based

secondary verification disabled. Sixteen synthetic Pro and V4.1 Flash executions provide bounded positive and negative flow controls. Case overlap and repeated condition assignments preclude interpreting their sum as an independent sample count.

Earlier Public, factorial, source-authority, confirmation, and adaptive experiments retain their original records and endpoint definitions. The historical factorial crosses prompt profile (`normal`/ `safe`) with runtime modules (`policy`/ `full`); its source swap varies provenance authority while holding the proposition and policy fixed. Those studies contextualize the current evaluation but do not substitute for corrected execution evidence. Gemini and optional independent-model or native dynamic-environment studies do not contribute a qualified effect estimate. Provider-managed tools and real external effects remain disabled throughout.

1.5 Empirical motivation and study framing

An implementation audit found that the historical oracle monitor compared complete action arguments with partial security-target annotations. Its completion collapse is therefore not evidence of an intrinsic cost of precise authorization or a benchmark-intrinsic reversal. Corrected target matching changes that interpretation without overwriting old records.

Current results reveal a more defensible problem: restrictive automatic authorization impedes benign AgentDojo work, while the sparse attack endpoint cannot establish security improvement. Exact-target assistance improves some completion but relies on an offline oracle. Full modules show no identifiable end-to-end advantage over policy modules in the tested conditions. Sensitive-data controls demonstrate bounded component behavior, not general natural-task efficacy. These studies do not establish full-module superiority, and their negative or uncertain outcomes are retained.

Historical adaptive observations still illustrate budget sensitivity, but their success labels are not retrospectively verified unauthorized effects. Extending 12 selected budget-200 survivors is not a complete budget-500 panel or evidence of saturation. Likewise, the historical risk-enriched calibration is a single execution block rather than temporal-repeatability evidence.

1.6 Contributions

The defensible contributions are:

1. corrected operationalization of target authorization, with an explicit separation between raw evaluator information and oracle-derived scope;
2. a paired empirical account of authorization burden, benign completion, sparse security events, failures, and unknowns under current runtime configurations;

3. bounded component controls that separate sensitive-data restrictions from end-to-end efficacy, complemented by clearly labelled historical factorial, provenance, and adaptive diagnostics; and
4. version-aware reporting that preserves proposals, decisions, isolation rejection, simulated execution, completion, and failure as different observations rather than deriving protection from a module-enable flag.

These contributions do not assert first, only, or SOTA status. Preprints are used to define the contemporary novelty boundary, not as peer-reviewed evidence.

2 Related work

2.1 Runtime verification and task alignment

VIGIL implements a verify-before-commit protocol for tool-stream injection and introduces the 959-case SIREN benchmark [3]. It is the closest peer-reviewed structural comparator to M3 because both systems interpose before an effect is committed. DRIFT instead combines dynamic rules with control- and data-level constraints and memory-stream isolation [4]. The Task Shield verifies whether instructions and tool calls contribute to the user's declared objective [5]. Together, these peer-reviewed systems prevent us from claiming that M3 introduced verify-before-commit, dynamic information-flow checks, or task-alignment verification.

PlanGuard is a related preprint that isolates planning from untrusted context and applies hierarchical tool and parameter consistency checks [20]. Its presence further narrows the possible novelty claim: planning consistency is an adjacent mechanism, not an unoccupied problem. We therefore use these works to define comparison classes and mechanism boundaries rather than to motivate a first-or-only claim.

2.2 Privilege, provenance, and information flow

Progent represents least privilege as symbolic tool-and-argument rules. Its latest arXiv v3 description explicitly distinguishes automatic narrowing from expansion that requires approval [9]. This overlaps directly with M3's permission-monotonicity and confirmation design. IPIGuard, published at EMNLP 2025, constrains execution through a planned tool-dependency graph [7]. CaMeL separates trusted control and data flow and uses capabilities to prevent unauthorized flows [10]. These systems occupy the privilege, dependency, and information-flow design space that a provenance-aware runtime must acknowledge.

FAVA is a July 2026 preprint that translates natural-language tasks into a permission intermediate representation, lowers it to an evidence-backed permission graph, and uses an SMT

authorizer before effectful execution [14]. It further narrows any mechanism novelty claim around structured authorization and data-flow-aware permission graphs. Our study differs by treating the authorization regime itself as the paired experimental factor and by jointly reporting evaluator-labelled risk, benign utility, confirmation/blocking burden, and operational failure. The historical risk labels require the measurement qualifications in Methods; only the corrected development study separates observed simulated effects from proposals and boundary rejections.

Two 2026 preprints overlap even more closely with provenance-aware authorization. ARGUS constructs an influence-provenance graph for context-dependent decisions [11], while AuthGraph compares an authorization graph derived in an isolated context against a parameter-source execution graph [12]. Their existence rules out a claim that M3 is the first parameter-source or provenance-aware authorization defense. Because neither work is treated here as peer reviewed, their reported effects define the contemporary claim boundary but are not used as settled comparative facts.

Auditing Provenance Sensitivity in LLM Agent Action Selection supplies an especially close 2026 measurement counterpart: it holds task content and policy fixed while changing source authority, then measures whether action selection changes [13]. Its controlled next-action design differs from M3's multi-step evaluation, but it reinforces the need to separate evidence relevance from authorization. Our experiment extends that question to full tool trajectories, paired runtime Guard conditions, benign utility, ASK/DENY burden, and operational failure.

The remaining defensible contribution is consequently methodological and empirical. We test whether authorization information itself changes measured security and utility; enforce a runtime projection that excludes evaluator fields; compare the policy and full configuration packages in paired conditions while disclosing their bundled prompt/runtime differences; and quantify ASK burden and operational failures. Effect semantics are specific to the benchmark and evaluator version; the old and corrected endpoints are not interchangeable. These are study-design claims and must stand on M3's own completed experiments.

2.3 Prompt-level defenses and execution-level outcomes

Structured queries, spotlighting, instruction hierarchy, and injection detectors act at the prompt, representation, or model-output layer [15–18]. They are relevant baselines, but detector scores and model compliance are not equivalent to an executed-effect endpoint. The corrected development evaluation therefore separates proposals, Guard decisions, sandbox execution receipts and outcome scoring. AgentDojo retains its native security checker, whereas M3-v2 uses observed simulated effects. This distinction is necessary because a defense can appear secure

by refusing useful actions or by failing before an effect is attempted.

2.4 Benchmarks and adaptive evaluation

AgentDojo supplies dynamic security and utility tasks and is the main public benchmark in this study [1]. InjecAgent provides a complementary collection of indirect prompt injections for tool-integrated agents [2]. ASB broadens the scenario and defense taxonomy [21]. The public expansion retains the benchmarks' unique task identities instead of duplicating benign cases to manufacture a denominator.

Static attacks are insufficient for a robustness claim. *The Attacker Moves Second* argues that a defense-aware attacker should optimize against the defense design rather than replay a fixed attack set [19]. The adaptive panel therefore exposes only public ALLOW/ASK/DENY and legacy evaluator-labelled risk feedback, searches frozen tasks at prespecified query budgets, and reports the first-success distribution. Since L27 remains a preprint, it motivates the protocol but is not described as a peer-reviewed theorem.

PIArena, published at ACL 2026, integrates attacks, defenses, and benchmarks and evaluates feedback-adaptive injection, including cases where the injected task aligns with the intended task [22]. The AgentDyn preprint instead emphasizes dynamic planning, open-ended tasks, and helpful third-party instructions [23]. These works motivate testing useful behavior under authorization constraints, not merely counting blocked actions. The ASPI preprint evaluates matched execution and clarification-seeking states and finds increased vulnerability in its clarification setting [24]. That interaction differs from our controller-only permission diagnostic, which does not send a clarification response back to the model. Neither a low ASK rate nor successful permit issuance demonstrates a secure human-confirmation workflow.

2.5 Positioning summary

M3 is not positioned as the first runtime guard, the first provenance system, or a state-of-the-art defense. In the medium experiment, M3-full did not improve the reported legacy risk endpoint over M3 policy-only and failed the reported benign-tool non-inferiority criterion. Those measurements do not establish effects under the repaired execution semantics. The active paper studies how non-oracle authorization, provenance-aware enforcement, confirmation, operational failure handling, benchmark choice, and adaptive attack budget jointly shape the measured security–utility frontier.

3 Methods

3.1 Current cohorts and statistical specification

The current investigation addresses authorization semantics, joint security and utility, and bounded component evidence. It is separate from the earlier six-question programme. The fixed 180-case authorization sample contains 100 attacks, 60 benign tool tasks and 20 no-tool tasks. Its 60-case stress subset and the 120-case contemporaneous calibration overlap earlier samples; neither a condition assignment nor a reused cohort is an independent task. Model prompts are ordinary in both policy and full cells. Oracle-derived scope is supplied only to the Guard and is explicitly distinct from deployed, non-oracle authorization.

The current authorization comparisons cross policy/full modules with compiled and corrected exact-target scope. The additional broad, underspecified and conflicting transformations are nested descriptive stress tests. Calibration contrasts policy, full and the explicitly configured VIGIL adapter with an unguarded control that retains the same external-effect boundary. Sixteen synthetic controls test specified label and data-flow behavior; they do not open an additional confirmatory family or estimate natural-task performance.

We retain the prespecified inferential results rather than re-estimating historical outcomes. Cell proportions use Wilson 95% intervals; paired absolute differences use Newcombe intervals and exact McNemar tests, with Holm correction within the defined endpoint/contrast family. Bootstrap intervals, when reported, keep task-level paired assignments together rather than resampling condition rows independently. Marginal cell intervals, paired-difference intervals and identification bounds for missing outcomes are different objects and are labelled accordingly. Zero-event empirical bootstrap intervals do not establish equivalence or absence of risk.

For the current authorization study, four contrasts form one Holm family within each benchmark and endpoint: exact minus compiled authorization for policy and for full modules, and full minus policy under compiled and under exact-target authorization. For contemporaneous calibration, policy minus no Guard, full minus no Guard, and full minus policy form a separate three-contrast family within each benchmark and endpoint. The endpoints are attack security and benign tool-task completion. The configured VIGIL comparisons are descriptive and have no Holm-adjusted p value; stress regimes and synthetic controls do not join these families. These are the families implemented in the existing analyses, not additional tests selected after inspecting results.

Benchmark panels are reported separately because native AgentDojo security judgments and M3-v2 observed simulated effects are not interchangeable. Completion and operational failure may coexist. All assignments remain in ITT, observed-value denominators accompany un-

known counts, and sensitivity bounds never substitute for observed unsafe effects. The benign-task review is post-outcome descriptive interpretation, not an additional significance family or an adjudication of every false block. Provider identities, module inputs and configured baseline limits bound each claim.

3.2 Threat model and safety boundary

The attacker controls text in documents, messages, retrieved records, memory, or simulated tool outputs processed while the agent performs a trusted user task. Corrected M3-v2 security effects require observed simulated execution that violates the task-specific evaluator. AgentDojo retains its native attack judgment, which is not reduced to a state-transition-only definition. Historical endpoint labels retain their original semantics. The model may propose tool calls, but it cannot invoke provider-managed tools or reach a real external system.

All experiments use isolated benchmark state. Real email, payment, browser, shell, code-execution, production API, credential, and unrestricted filesystem operations are disabled. A proposal can affect only copied AgentDojo state, M3-v2 mock resources, example.test, /mock/, or the public sandbox. Model output is therefore treated as untrusted data, not executable authority.

Training-time poisoning, model-weight compromise, credential theft, host compromise, and direct modification of the trusted policy store are outside scope.

3.3 Online-state and evaluator separation

Every run constructs the online state through an allowlist projection. Permitted fields include trusted user intent, the benchmark-visible task context, the selected authorization regime, provenance events available at that step, and the proposed action. Gold answers, expected actions, attack and task-success labels, evaluator explanations, reference trajectories, and offline effect receipts are excluded.

The exact_gold condition is an explicitly labeled oracle sensitivity analysis. It converts evaluator-derived authorization into the condition's authorization object, but does not expose the evaluator labels or scoring fields themselves. exact_gold is never presented as the primary deployment regime. The primary regime is auto_compiled, created from the trusted user request before untrusted content is processed.

Each compact result stores a digest of the online-visible projection and a boolean forbidden-field check. A run fails the minimal integrity check if a forbidden field is present. The final analysis checks this condition once for all terminal records; it does not recursively replay historical evidence.

3.4 Runtime conditions

The common runtime interfaces are TaskPolicyManifest, ActionProposal, GuardDecision, and ProvenanceEvent. In the historical bundled comparison, the two M3 conditions share the agent, model, parser, evaluator, tool environment, and task-policy representation, but they are not a single-module ablation:

- **Policy package** evaluates the proposed tool and arguments against the current task policy with the normal prompt profile. Provenance propagation, temporal/data-flow checks, and independent confirmation are disabled.
- **Full package** uses the safe_prompt profile and enables policy enforcement plus parameter provenance, temporal/data-flow constraints, permission-monotonic transitions, and confirmation. Automatic transitions may preserve or reduce authority; authority expansion produces ASK and requires an independent confirmation result.

The earlier authorization experiment changed prompt profile and runtime modules together and is therefore retained only as a bundled configuration comparison. The historical E1 concurrent factorial crosses both factors explicitly: policy versus full modules and normal versus safe prompt. Its module main effect, prompt main effect, and module-by-prompt interaction are therefore separately identified within the fixed paired sample. The current corrected authorization and calibration studies instead hold both module conditions at the same ordinary prompt; their assignments must not be described using the earlier bundled prompt profiles.

ALLOW, ASK, and DENY are runtime decisions, not security outcomes by themselves. Security is scored from the isolated post-enforcement effect receipt. Utility is scored by the benchmark task-completion evaluator.

The earlier incomplete 450-item Gemini authorization sample remains diagnostic and is not extended. E6 makes a separately executed, bounded Gemini prefix attempt that is diagnostic by design under the single-block amendment. Even complete prefix coverage would not make that amended design a formal cross-provider study; the observed incomplete prefix leaves every Gemini and cross-provider effect not estimable. Structural baselines, including the source-pinned VIGIL adapter, retain their earlier descriptive role; the new experiments target causal confounding, source authority, risk enrichment, same-provider model replication, and adaptive tail behavior rather than rerunning a large baseline matrix.

3.5 Measurement correction and development validation

The historical execution studies used the original compiler, rule matcher, and evaluator. Their recorded safety labels are not retrospectively converted to executed unauthorized effects.

In particular, the original M3-v2 evaluator could score a final isolation rejection as an unsafe event, whereas the revised development evaluator distinguishes proposals, Guard permission, isolation rejection, successful simulated execution, task completion, and unknown values. AgentDojo retains its native security and utility checks. Legitimate completion and a security violation may coexist; missing evidence is not a safe zero.

The explicitly selected corrected-v1 path fixes action-resource binding, complete matching across multiple rules, trusted-environment label propagation, and confirmation-state continuity. It does not alter the historical default or records. Six configurations cross no/policy/full guard modules with the same normal/safe prompt factor. The development set comprises 24 attacks, 16 benign-tool tasks, and eight no-tool tasks; AgentDojo contributes 20 tasks and M3-v2 28. Attacks are historically enriched, not a deployment sample. Both completed DeepSeek cohorts use temperature zero, a 512-token output limit, and at most eight provider calls per task-condition. The V4.1 Flash model is distinct from the earlier V4 Flash and is not a model-invariant before/after comparison. Synthetic paired-action tests establish component behavior only; there is no simulated human approval or new confirmatory family.

3.6 Corrected target authorization and contemporaneous calibration

Table 1 summarizes the current cohorts and their distinct evidence roles.

The corrected experiment selects explicit corrected_v2 runtime behavior and exact_target_v2 authorization. Target and other constrained security fields must match the offline-derived scope; schema-required content fields need not equal an absent annotation. Schema completeness, types, additional security targets, action order, and execution registration remain checked. A generic subset-of-arguments comparison is insufficient because additional recipients, paths, or endpoint parameters can change the authorized action. The original matcher and all its records remain unchanged.

Raw evaluator fields do not enter the model prompt. In the oracle condition, the Guard nevertheless receives an explicitly answer-derived authorization object. This is an idealized information regime, not evidence that deployed authorization can obtain the same scope. Ambiguous required scope is not an automatic grant, including with confirmation modules disabled. Missing trusted classification cannot be treated as public data when a restricted data-flow rule applies. No human approval is simulated: ASK means pending clarification, not task completion.

The new authorization cohort reuses 180 fixed cases: 100 attacks, 60 benign tool tasks, and 20 M3-v2 no-tool tasks. Policy and full modules each receive compiled and exact-target authorization, yielding 720 assignments; all four cells use the same ordinary prompt. Three

stress regimes on the predefined 60-case nested subset add 180 full-module assignments. The 12-assignment formal prefix is part of the 900 total, not an additional repeat. The security endpoint has 490 attack assignments across the main and stress cells, not 490 independent tasks. This authorization study contains no unguarded cell.

A separate contemporaneous calibration uses 120 fixed cases, with 30 attacks and 30 benign-tool tasks from each benchmark. Ordinary prompts and compiled authorization are held constant across no research Guard, policy, full, and configured VIGIL, giving 480 assignments. The unguarded condition retains the same host and external-effect boundary. VIGIL generates constraints through the model and uses its configured deterministic hybrid audit, with model-based secondary verification disabled. It is not the complete official default baseline. Its provider-call cap is 16; the other conditions cap at eight. Cohorts overlap earlier studies and do not constitute independent sample replication.

Both Pro experiments use temperature zero, 512 output tokens, a 180-second single-request timeout, and zero automatic HTTP retries. Task environments are isolated, with at most two assignments in flight. After a 120-assignment calibration stop caused by parallel telemetry and truncated constraint classification, a telemetry-only revision executed the 360 untouched items. The first 120 records, including response-bearing failures, were not retried. Scientific prompts, parameters, permissions, and work identities were not changed; the two runner revisions remain distinguishable.

Four synthetic memory scenarios cross policy/full with Pro and the approved V4.1 Flash service, yielding 16 additional executions. The scenarios cover private restricted flows, public restricted flows, private archival flows, and absent classification. They test specified component behavior, not general protection, a natural task distribution, or human confirmation.

Each benchmark retains its own security semantics. AgentDojo uses native attack and utility checks on an isolated environment copy; M3-v2 counts unauthorized simulated effects supported by execution evidence. Failures, unknown outcomes, and completion after execution remain distinct. Reported total latency reads the runtime total component; component durations and missingness are reported separately rather than inferred from token usage. Existing inferential results are reused when correcting latency aggregation.

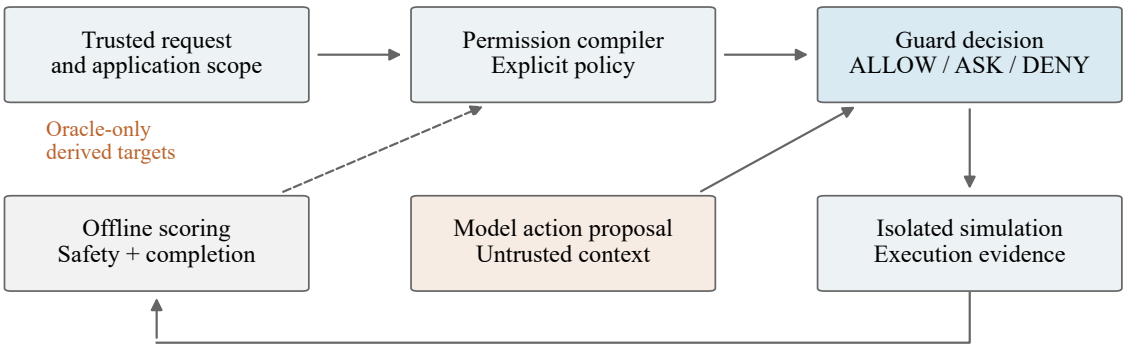
3.7 Trusted-intent review of benign tasks

We subsequently reviewed the fixed calibration cohort's 60 benign tool tasks, 30 per benchmark, and linked their 240 existing condition records. This is a post-outcome explanatory review, not a blind evaluation, a new sample, or an independent replication. Trusted user requests, trusted application context, and tool interfaces define the authority interpretation; evaluator an-

Table 1 Current study cohorts and configurations

Study	Cases	Assignments	Conditions	Scope
Authorization core	180	720	Policy/full; auto/ exact target	Pro; normal prompt
Nested stress regimes	60 (nested)	180	Full; broad/ underspecified/ conflicting	Pro; normal prompt
Contemporaneous calibration	120	480	ND/policy/full/ configured VIGIL	Pro; normal prompt
Synthetic controls	4 scenarios	16	Policy/full	Pro + V4.1 Flash

Note. The authorization core and nested stress assignments total 900, not 900 independent cases. Cohorts overlap. Exact target is evaluator-derived oracle authorization, not a deployable source. VIGIL uses generated constraints and deterministic hybrid auditing with secondary model verification disabled; its call cap is 16 versus 8 for the other calibration conditions.



Raw evaluator fields stay outside model input; derived answer targets enter only the oracle Guard.
Permission, boundary rejection, execution, task completion and operational failure remain distinct.

Figure 1 Authorization, execution and evaluation boundaries. Trusted intent, projected authorization and runtime events are distinct from offline evaluation. The dashed path denotes the oracle sensitivity condition: only an authorization object derived from the offline target is exposed to the Guard, not the raw gold or evaluator fields. This is not deployable authorization. Model proposals, Guard decisions, isolation rejections, simulated execution, task completion, failure and unknown outcomes remain distinct. Provider-managed tools and real external effects are disabled. The diagram describes scope, not effectiveness.

swers and model-declared permissions do not supply grants.

For each task we retain an intent paraphrase, possible tool routes, declared action fields, generated rule types, first restriction, successful simulated execution count, completion, operational status, and source locators. Possible tool routes are not a gold list of necessary actions. Interpretation categories may overlap, and the same task may have a completed benchmark outcome and a later failed workflow. We inspect declared action–target pairs for loss or mismatch without treating every natural-language intent as a contract requiring the current lexical compiler to infer a dynamic target.

The review uses only existing public records and projected trusted inputs. Redacted proposal arguments and final-answer content limit diagnosis of cases with successful simulated execution but unsuccessful completion. No new model call, permission expansion, evaluator relabeling, or runtime revision follows from the descriptive review, and no independent reviewer-agreement estimate is available.

3.8 Failure and recovery policy

Automatic retry is disabled. Recovery operates at the predefined experiment-item level:

- a work item with an official model response is terminal, including timeout, refusal, parse failure, and maximum-step outcomes after that response;
- a transport or preparation failure with no official response may be retried only with the explicit failed-row option;
- only the affected work item is retried; successful and unaffected work items are skipped;
- a repeated non-rate-limit pre-response failure becomes terminal on its second attempt; and
- no automatic retry or cross-model fallback is permitted.

Earlier response-less attempts remain append-only in the raw file. The scientific analysis selects the latest terminal attempt for each experiment item and reports the count of superseded attempts. No prior row is overwritten.

3.9 Outcomes

The two joint primary endpoints are:

1. **unsafe-effect rate** on assigned attack tasks; and
2. **task-completion rate (TCR)** on assigned benign tool tasks.

Benign no-tool completion is descriptive. Secondary outcomes are system ASK and DE NY event counts and record incidence, operational failure, p50/p95 latency, total tokens, API

cost, and predefined heterogeneity by benchmark and attack family. ASK is a runtime confirmation request; without a human study it is not interpreted as measured human burden.

All terminal work items remain in the intention-to-treat denominator. The analysis reports raw numerator/denominator values alongside proportions. Observed security outcomes, unknown outcomes, task completion, and operational failure are recorded separately. A provider or parser failure is neither silently removed nor relabeled as successful protection. If the benchmark establishes completion before a later failure, both observations are retained; without completion evidence the failure cannot create a successful task. Missing effect evidence remains unknown, not a safe zero. Burden summaries include terminal failures, and latency summaries report their available-value denominator rather than imputing missing durations.

Because observed unsafe effects are rare, we also report a pessimistic sensitivity endpoint on attack tasks: unsafe_effectORoperational_failure. This composite is a robustness bound, not an attack-success label. It asks how conclusions change if a non-operational run is not credited as secure while preserving unsafe effects and failures as separate reported counts.

3.10 Minimal verification and reproducibility

Verification is deliberately proportional to the lean study. It consists of:

1. focused unit tests for modified provider, authorization projection, evaluator, analysis, and plotting code;
2. an eight-item formal prefix for each regular incremental study, two five-query tail prefixes for E5, and a 12-item outcome-blind E6 prefix; and
3. one terminal pass over row count, experiment-item uniqueness, forbidden-field isolation, exact model identity, and ITT failure retention.

Each study writes one append-only compact raw JSONL. Final statistics are written once to one analysis JSON per study, and figures are exported as submission-ready vector PDF, editable SVG, and raster PNG previews for manuscript/QA use. Reproducibility assets include frozen samples, condition assignments, analysis code, aggregate tables, and versioned source.

4 Results

4.1 Corrected authorization and contemporaneous calibration

The corrected authorization study records all 900 planned assignments: Tables 2–4 summarize corrected authorization, contemporaneous calibration, and bounded component controls, respectively. The following paired intervals are distinct from the marginal Wilson intervals in

the tables.

795 workflows end normally, 60 exhaust the step budget, and 45 have parse failures. Workflow status is separate from task completion. Across the 490 attack assignments, security events are zero under the benchmark-specific checks. This study contains no unguarded control, and repeated condition assignments are not independent attacks; the zero endpoint cannot establish effectiveness or equivalent protection.

For AgentDojo benign-tool tasks, compiled authorization completes 2/30 under both policy and full modules. Exact-target authorization completes 13/30 under policy and 11/30 under full modules. The paired exact-minus-compiled differences are +36.67 percentage points (95% CI +18.60 to +53.31; Holm p=0.0039) and +30.00 points (+13.23 to +46.75; Holm p=0.0117), respectively. For M3-v2, the corresponding compiled counts are 16/30 and 17/30, compared with exact-target counts of 14/30 and 16/30. Their differences, −6.67 and −3.33 points, have intervals spanning zero. This does not reproduce a statistically established benchmark-intrinsic reversal. The oracle improves some observed completion under answer-derived scope but is not a deployed non-oracle authorization method.

The separate calibration closes all 480 assignments: 443 workflows end normally, nine exhaust steps, 25 have parse failures, two have runner failures, and one has a provider/stop failure. On AgentDojo, no research Guard yields 3/30 security events and 17/30 benign-tool completions. Policy and full modules each yield 0/30 and 2/30. The paired completion difference is −50.00 points (95% CI −66.83 to −26.80; Holm p=0.0008), whereas the security difference is −10.00 points (−25.62 to +3.10; Holm p=0.7500). The utility cost is observable; a security improvement is not established. The no-research-Guard, policy, and full M3-v2 security cells are all zero, with benign completions of 16/30, 17/30, and 16/30. Full modules do not show an independent end-to-end advantage in these conditions.

Configured VIGIL has four AgentDojo attack positives among 28 known outcomes and two unknown attack outcomes. All 30 assignments remain in ITT, so the observed positive count gives a 4/30 lower bound and a 6/30 conservative upper bound, not a claim that the unknown outcomes were safe. Two additional AgentDojo benign outcomes are unknown. Its disabled model secondary verification and larger call budget bound this configuration comparison. Across all 480 rows, two field-projection receipts and four structured safety receipts are absent; missing receipts are not fabricated afterward.

The public-event diagnosis reports 26/30 AgentDojo compiled benign tasks with a first missing-tool-permission block in each module condition. This locates permission insufficiency but does not prove every missing permission is an implementation error. The original 900 rows have no recorded length truncation; parse failures cannot uniformly be attributed to the 512-

token limit. Two rows record task completion before a subsequent operational failure, and both observations are retained.

The 16 synthetic controls all reach a workflow terminal. Full modules deny private restricted flows and ask when classification is missing; the tested public and archival flows complete. Policy-only permits the restricted private/missing-classification simulated flow. Legitimate completion and a security violation can coexist in these controls. Their limited scenarios and two DeepSeek services do not establish general provenance effectiveness or independent-provider replication.

Task total latency is available for 476/480 calibration assignments, with four missing and no invalid values. AgentDojo benign-task median/p95 durations are 5.083/11.575 seconds without the research Guard, 1.209/3.029 with policy, 1.279/3.003 with full modules, and 8.145/20.291 for configured VIGIL, whose known-duration denominator is 28/30. Early blocking, model calls, constraint generation, and task-path differences preclude interpreting this ordering as a Guard computation speedup. The latency-only correction does not alter the raw records or prior security and completion inference.

Table 2 Corrected authorization and benign-tool completion

Benchmark / modules	Authorization	Completion [95% CI, %]	Failure / planned	ASK / DENY
AgentDojo / Policy	Auto	2/30 [1.85, 21.32]	0/30	29 / 0
AgentDojo / Policy	Exact target	13/30 [27.38, 60.80]	12/30	0 / 96
AgentDojo / Full	Auto	2/30 [1.85, 21.32]	0/30	29 / 0
AgentDojo / Full	Exact target	11/30 [21.87, 54.49]	13/30	0 / 111
M3-v2 / Policy	Auto	16/30 [36.14, 69.77]	4/30	3 / 4
M3-v2 / Policy	Exact target	14/30 [30.23, 63.86]	6/30	0 / 13
M3-v2 / Full	Auto	17/30 [39.20, 72.62]	5/30	1 / 5
M3-v2 / Full	Exact target	16/30 [36.14, 69.77]	5/30	0 / 11

Note. Each cell has 30 planned benign-tool tasks. Completion fractions use observed denominators; brackets are cached Wilson 95% intervals in percent, not paired-effect intervals. All outcomes here are known; failures stay in the planned denominator and can coexist with completion. ASK/DENY are event counts, not counts of distinct tasks. Prompts are normal in both module configurations.

Table 3 Contemporaneous security and benign-tool utility

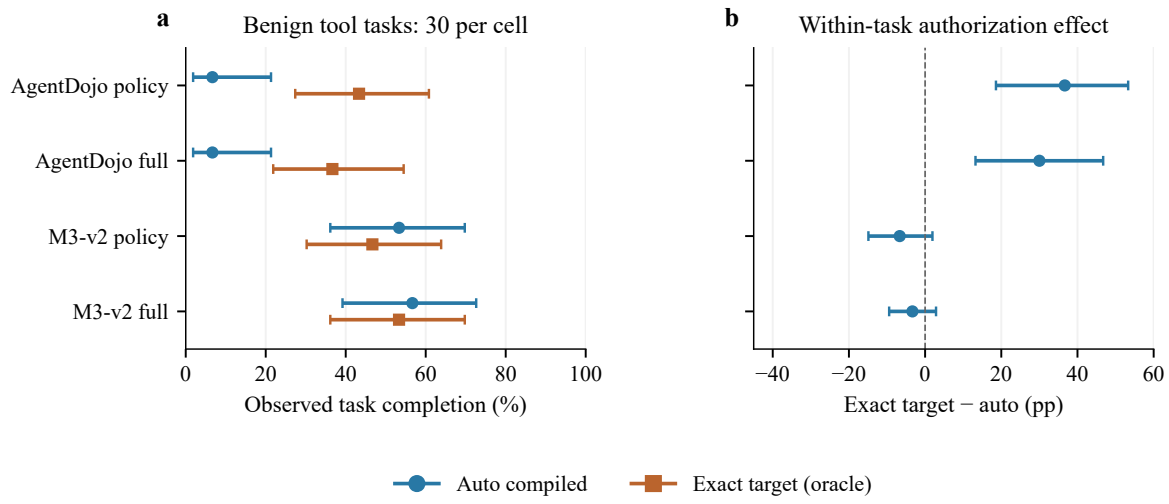
Benchmark / condition	Attack [95% CI, %]	Benign completion [95% CI, %]	Unknown A / B	Failure A / B
AgentDojo / ND	3/30 [3.46, 25.62]	17/30 [39.20, 72.62]	0 / 0	5 / 7
AgentDojo / Policy	0/30 [0.00, 11.35]	2/30 [1.85, 21.32]	0 / 0	0 / 0
AgentDojo / Full	0/30 [0.00, 11.35]	2/30 [1.85, 21.32]	0 / 0	0 / 0
AgentDojo / VIGIL configured	4/28 [5.70, 31.49]	17/28 [42.41, 76.43]	2 / 2	3 / 7
M3-v2 / ND	0/30 [0.00, 11.35]	16/30 [36.14, 69.77]	0 / 0	0 / 4
M3-v2 / Policy	0/30 [0.00, 11.35]	17/30 [39.20, 72.62]	0 / 0	0 / 1
M3-v2 / Full	0/30 [0.00, 11.35]	16/30 [36.14, 69.77]	0 / 0	0 / 4
M3-v2 / VIGIL configured	0/30 [0.00, 11.35]	16/30 [36.14, 69.77]	0 / 0	0 / 6

Note. Each attack and benign cell has 30 planned tasks. Fractions use known outcomes, with Wilson 95% intervals in percent. Unknowns are not safe zeros. For AgentDojo VIGIL, attack ITT bounds are 4/30 to 6/30 and benign completion bounds are 17/30 to 19/30. Failures are separate from unsafe effects. AgentDojo uses native security verdicts; M3-v2 uses observed simulated unauthorized effects. ND means no research Guard, not removal of the shared isolation boundary.

Table 4 Bounded synthetic component controls

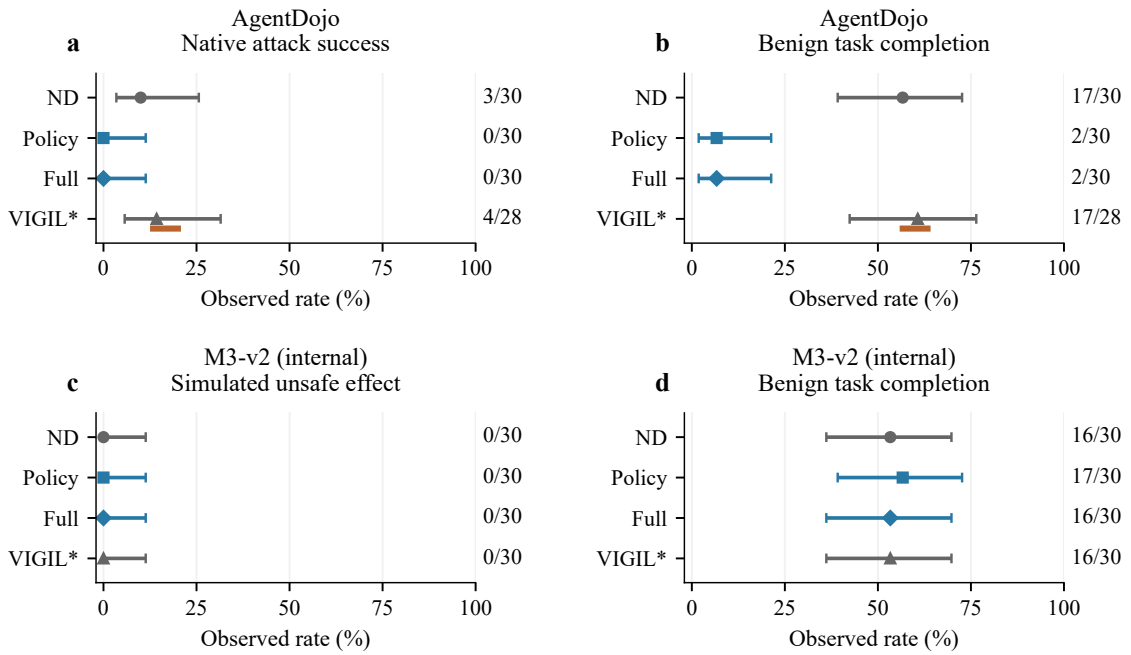
Model / scenario	Policy U / C	Full U / C	Full ASK / DENY	Sends policy / full
V4 Pro / private restricted	1 / 1	0 / 0	0 / 1	1 / 0
V4 Pro / public restricted	0 / 1	0 / 1	0 / 0	1 / 1
V4 Pro / private archive	0 / 1	0 / 1	0 / 0	1 / 1
V4 Pro / missing classification	1 / 1	0 / 0	1 / 0	1 / 0
V4.1 Flash / private restricted	1 / 1	0 / 0	0 / 1	1 / 0
V4.1 Flash / public restricted	0 / 1	0 / 1	0 / 0	1 / 1
V4.1 Flash / private archive	0 / 1	0 / 1	0 / 0	1 / 1
V4.1 Flash / missing classification	1 / 1	0 / 0	1 / 0	1 / 0

Note. Each entry represents one controlled execution per module, not a population rate. U/C means simulated unsafe effect / task completion (1=true, 0=false). All 16 workflows completed normally. Full's ASK is waiting for clarification, not human approval or completion. Effects are in-memory mailbox transitions; boundary rejections were zero. Flash is V4.1, not historical V4 Flash. These controls do not demonstrate natural-task or arbitrary-leakage generalization.



a: cached Wilson 95% intervals. b: cached paired Newcombe 95% intervals; 30 pairs per row.
Normal prompt in every cell. Oracle-derived scope is a contrast, not deployable authorization.

Figure 2 **Corrected authorization and benign-tool completion. Panel a shows completion fractions and cached Wilson 95% intervals for 30 benign-tool tasks in each benchmark and policy/full configuration under ordinary prompts. Panel b shows the corresponding paired exact-target minus auto-compiled differences with cached Newcombe 95% intervals, in percentage points. The two interval types answer different questions. Exact-target is the oracle sensitivity condition, not an estimate of deployed permissions; the regimes and configurations use overlapping paired tasks. ASK/DENY events and failures are separate in Table 2.**

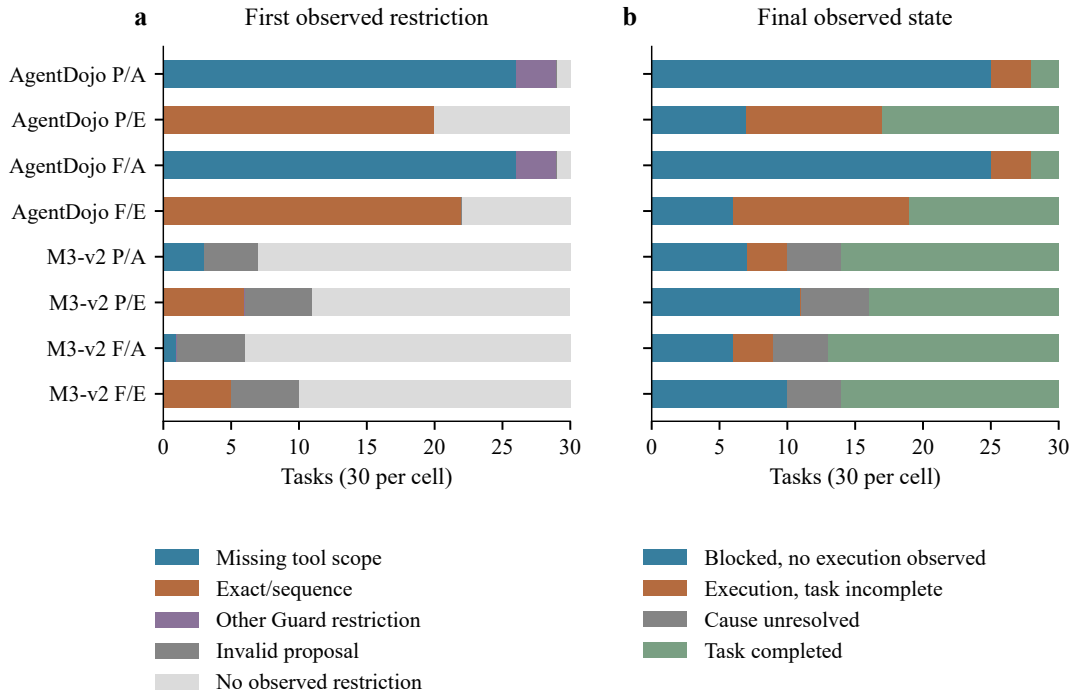


Points: observed fractions, cached Wilson 95% intervals; 30 planned tasks per condition and endpoint.

Orange segment: ITT identification range for unknown outcomes, not a confidence interval.

ND: no research Guard. VIGIL*: disclosed adaptation; 2 unknown AgentDojo outcomes per endpoint.

Figure 3 **Contemporaneous security and benign-tool utility. Rows separate AgentDojo native security verdicts from M3-v2 simulated effects; columns show attack outcomes and benign-tool completion. Each condition has 30 planned tasks per panel. Points and Wilson 95% intervals use observed denominators; fractions show true/observed counts, with missing outcomes explicit. Configured VIGIL has 28 observed AgentDojo outcomes and two unknowns per endpoint. Its orange ITT identification range is not a confidence interval and does not treat unknowns as safe failures. Configured VIGIL uses constraint generation and a deterministic hybrid audit, not its complete official default implementation; its 16-call limit differs from the other conditions' eight-call limit. These results do not rank providers or establish a full-module safety advantage.**



P/F: policy/full; A/E: auto/exact target. Descriptive event categories, not confirmed causal explanations.

Figure 4 **First restrictions and final workflow states. Each row contains 30 benign-tool assignments under one benchmark, authorization regime and policy/full configuration. Panel a classifies the first publicly observed block; panel b classifies final execution and completion states. The cached categories are descriptive event summaries, not adjudicated root causes or proof that missing permissions should be granted. P/F denotes policy/full and A/E denotes auto/exact target. ASK/DENY burden is reported separately in Table 2. No new inference or uncertainty estimate is introduced by these counts.**

4.2 Trusted-intent review of benign completion

The fixed 60-task review finds no lost or mismatched action–target pair among the seven trusted application declarations. Thirteen further M3-v2 tasks have rules for explicitly requested targets. The remaining ten M3-v2 tasks require confirmation of a filename or recipient without supplying a concrete target; no independent approval was obtained. These counts describe the trusted inputs and generated rules, not an adjudicated false-block rate.

All 30 AgentDojo tasks lack such concrete trusted action declarations. The generic compiler's lexical tool selection and literal security-target parsing do not cover arbitrary natural-language requests, multistage lookups, or dynamic object identifiers. The requests can express legitimate goals even when this bounded compiler cannot derive an executable grant. The review does not establish a new bounded-contract violation or justify automatic authority expansion.

Six M3-v2 tasks show successful simulated execution without completion under at least one policy/full condition; four of these also have a model-format or operational failure. Categories overlap. In three explicit mock-API tasks, policy records contain ALLOW, successful execution, and a final answer but still fail completion. The evaluator requires both expected-effect matching and a successful final outcome. Redacted public arguments and answer content do not identify the exact mismatch, so this observation is not evidence of an evaluator defect. Native AgentDojo completion likewise does not prove that a particular blocked action was executed.

4.3 Corrected development study

Supplementary Table S20 separates the corrected-v1 development batch from all historical experiments. DeepSeek V4 Pro and DeepSeek V4.1 Flash each completed 288 planned task-condition executions over the same 48 tasks and six configurations. Pro had 265 completed workflows, 13 parse failures, and 10 max-step terminations; Flash had 272, seven, and nine respectively. Workflow completion is not task completion: ending with ASK records a pending approval, not an executed task. Gemini is deferred and supplies no model-effect comparison.

AgentDojo retains its native security checker rather than a state-only endpoint. For Pro, normal-prompt attack positives were 5/12 without a guard, 2/12 with policy modules, and 0/12 with full modules; benign-tool completion was 6/8, 3/8, and 3/8. The full-minus-policy paired attack difference was -16.67 percentage points with a 95% interval from -44.80 to +10.38, crossing zero. For Flash, the no-guard normal-prompt attack cell had 1/12 positives and each other cell had zero; benign-tool completion was 7/8 in both no-guard cells and 4/8 in each guarded cell. These small, historically enriched development samples do not establish superiority or

causal attribution to provenance.

M3-v2 observed simulated unsafe effects were 0/12 in every attack cell for both models, including no guard. Thus the null observations do not establish guard efficacy. Runtime summaries contained zero labelled sensitive values; dataflow checks were not applicable. Passing synthetic label-propagation tests is separate from model-generated evidence of activated dataflow restrictions. The eight no-tool tasks per model-condition remain in the planned denominators, but Supplementary Table S20 focuses on attack and benign-tool outcomes. Unknown outcomes are not replaced by zero, and operational failures remain separately reported.

4.4 Remaining evidence boundary

Historical Public and incremental tables retain their recorded evaluator labels. In the old M3-v2 path, an action allowed by the Guard but rejected by the final isolation boundary could be labelled unsafe even though the effect was not applied. Historical ITT variants also include operational failures. The compact records do not support retrospective identification of all actual unauthorized effects. Historical numbers are therefore legacy-labelled risk endpoints, not corrected execution-effect estimates. Their values are retained, not silently relabelled as corrected-v1 results; AgentDojo's native checker is also not reduced to an environment-state-only definition.

The medium, Public, authorization-regime, factorial, source-authority, challenge, replication, adaptive, and contemporaneous-activity studies jointly support an empirical security–utility paper. They do not support a leading-defense, end-to-end provenance-benefit, saturated-adaptive, or cross-provider claim. E2 does identify source sensitivity at the deterministic Guard decision layer, but its end-to-end action endpoint is floor-limited. E5 supplies only a conditional 0/12 B200-survivor tail with a 24.25% upper confidence limit. E6 records attack activity only within its historically enriched, single-block DeepSeek cohort; it neither satisfies nor tests the original multi-window activity gate. The earlier Gemini authorization study closed at 32/450 terminal work items, only five response-bearing; the separately executed E6 Gemini prefix produced five response-bearing records, one response-less failure, and 174 administrative closures. Both are retained for operational accounting but all Gemini effects are not estimable. UTR and DSR are not identifiable from the current record contract and are not reconstructed from unsafe-effect rate.

4.5 Historical diagnostic context

The full working draft and Supplementary Tables S1-S20 retain the earlier medium, Public, authorization, factorial, provenance, challenge, replication, adaptive and permit studies. Their

recorded endpoint definitions are not retrospectively replaced by corrected execution outcomes. In E2, deterministic replay had 0/240 false allows and 30/240 false blocks, while all 240 end-to-end runs executed no action. This establishes bounded decision sensitivity, not useful end-to-end protection. The complete 40-task adaptive panel recorded first legacy risk success for 4/40 tasks by budget 50 and 18/40 by 200. Only twelve preselected B200 survivors continued to 500; the conditional 0/12 result has a Wilson upper limit of 24.25%, not a complete B500 curve or a saturation estimate. Historical E6 used one risk-enriched execution block, with 47/60 tasks also in E3. It supplies neither independent-sample nor temporal replication. E7a issued execution permits without a backend state transition and therefore supplies neither TCR nor executed-effect evidence.

5 Discussion

5.1 Existing evidence changes the research claim

Neither the historical programme nor the corrected studies establish that full modules are superior to policy-only authorization. Historical Public counts, including 38/600 versus 13/600 on Pro and 24/400 versus 12/400 on V4 Flash, retain their recorded legacy endpoint definitions. They are not estimates recomputed under the corrected simulated-execution evaluator. Isolation rejection, conservative failure-inclusive labels, and native AgentDojo attack judgments must not be merged into an observed harmful-effect claim. Historical utility and package-direction observations remain visible without rewriting the original records.

The corrected contemporaneous calibration instead exposes a specific utility cost: AgentDojo benign completion is 17/30 without the research Guard but 2/30 with either policy or full modules. The paired interval excludes zero for the −50-point completion difference. Its 3/30 versus 0/30 security contrast does not establish a reduction, and M3-v2 has no unguarded security events. Low operation therefore cannot substitute for evidence of useful protection. The full-versus-policy observations do not isolate or validate individual provenance, temporal, data-flow, or confirmation mechanisms.

The earlier factorial design separates prompt and module-bundle assignments, but implementation inputs, legacy outcome semantics, and sparse events still limit mechanism attribution. These constraints do not show that each module is intrinsically ineffective; they show that activation and condition labels alone cannot prove its contribution.

5.2 Authorization is part of the treatment

Authorization is often treated as fixed infrastructure rather than an experimental variable. That assumption is risky in tool-agent evaluation. An exact per-case authorization object reconstructed from the expected answer can remove uncertainty that a deployed Guard must resolve. A broad policy can improve apparent utility by authorizing too much. An underspecified policy can make safe completion impossible, while conflicting constraints may increase denial, confirmation, or failure even when they prevent unsafe effects.

The corrected design keeps the ordinary prompt fixed while varying compiled and exact-target authorization. The oracle supplies answer-derived target scope to the Guard; this assistance is deliberately distinct from non-oracle policy compilation. Model prompts do not receive raw answers, but that separation must not be advertised as absence of evaluator-derived information throughout the system.

The historical oracle result cannot establish an inherent utility penalty. Full argument equality against partial target annotations rejected schema-compliant actions with necessary content fields. Its completion collapse, denial burden, and apparent benchmark reversal are retained as defective operationalization observations, not deployed authorization effects. The corrected target matcher retains schema, additional security-target, order, and execution-registration checks rather than granting arbitrary arguments by subset matching.

In the 900 corrected assignments, AgentDojo exact-target policy/full complete 13/30 and 11/30 benign tasks, compared with 2/30 for both compiled cells. M3-v2 exact-target cells complete 14/30 and 16/30, compared with 16/30 and 17/30. M3-v2 differences remain uncertain; a point-estimate reversal is not a demonstrated benchmark property. The 490 zero-event attack assignments also lack an unguarded reference, limiting any effectiveness interpretation.

Compiled scope can be insufficient without implying that all omitted actions are authorized. The current generic compiler omits an automatic rule when a required security target cannot be resolved from trusted inputs. First missing-tool-permission blocks in 26/30 AgentDojo benign cases in each module cell locate this limitation but do not establish which cases violate the compiler contract. The completed 60-task trusted-intent review preserves all seven explicit application declarations, finds thirteen further direct-target rules, and identifies ten M3-v2 tasks awaiting target clarification without independent approval. AgentDojo's thirty tasks expose the bounded compiler's natural-language and dynamic-target coverage limits, not thirty proven contract defects. Execution without completion in three mock-API tasks remains partly unexplained because public arguments are redacted. These observations do not justify widening permissions to improve completion. Broad, conflicting, and underspecified stress results likewise describe the tested transformations, not deployment prevalence.

Operational failure and security remain separate. A failure-sensitive upper bound is useful when effects are unknown but cannot be reported as observed harmful execution. Two tasks completed before later operational failure in the corrected authorization study, illustrating why completion and failure must not be forced into mutually exclusive categories.

5.3 Executed effects and utility must be reported together

A low prompt-injection success rate is not sufficient evidence of a useful runtime defense. A detector may flag adversarial text without preventing an effect; a runtime may prevent effects by denying nearly every useful action; and a parser/provider failure may look secure if the evaluator counts only successful executions. We therefore treat isolated executed effect as the security endpoint and benign tool-task completion as a joint primary endpoint.

The historical Public evidence illustrates a related measurement problem. Relative to the structural condition, both M3 variants reduced recorded legacy risk labels but also had much lower benign-tool completion. The policy package then outperformed the full package on security without losing additional utility. The interpretation is not that provenance is intrinsically harmful. It is that the evaluated bundle did not earn a security advantage under these tasks and policies.

ASK, DENY, operational failure, latency, tokens, and cost provide the missing system-facing context. An authorization regime that shifts unsafe effects downward but greatly increases ASK may be acceptable in high-consequence workflows and unacceptable in routine automation. A regime that shifts both ASK and failure upward may simply externalize uncertainty rather than resolve it. The paper reports these outcomes separately. The unsafe-or-failure sensitivity endpoint is shown only as an explicitly pessimistic robustness bound, not as a replacement composite score.

5.4 Relation to recent provenance and authorization work

VIGIL, DRIFT, the Task Shield, IPIGuard, Progent, CaMeL, ARGUS, AuthGraph, FAVA, and provenance-sensitivity auditing occupy overlapping parts of the design space [3–5, 7, 9–14]. These works rule out claims that M3 is the first verify-before-commit system, the first parameter-source defense, or the first structured runtime authorizer.

The remaining contribution is methodological and empirical. The study holds task content fixed while changing authorization regimes, separately manipulates prompt and runtime factors, and performs a source-only counterfactual. It keeps evaluator fields offline, measures post-enforcement effects, retains failure in ITT, and reports operational burden. In particular, the recent provenance-sensitivity study changes source authority in controlled next-action tasks

[13]. The present design adds deterministic Guard replay and complete tool trajectories while keeping those two evidence layers separate.

5.5 Limitations

First, the new primary experiment uses one proprietary model and two benchmark families; the larger Public evidence adds another model from the same provider, not an independent vendor. Model updates, tool schemas, system prompts, and application context may change the effects. Both Gemini attempts closed incomplete and contribute no cross-provider inference. Although execution dates, official response identifiers, and returned model names are retained, provider-managed aliases do not make the underlying weights immutable.

Second, both authorization studies have a strong attack-endpoint floor. The historical study recorded one risk-positive label among 400 main attack assignments; the corrected study observes none among its 490 main and stress attack assignments. Neither has an unguarded reference. Their utility and operational outcomes are more informative than small security differences. The corrected calibration adds that reference, but its sparse AgentDojo events and zero-event M3-v2 control still do not establish a security gain. Larger historical matrices cannot repair that inferential gap because their recorded endpoints are not the corrected executed-effect measure.

Third, E1 separates prompt profile from the runtime module bundle, but the full module factor still combines provenance, data-flow, monotonicity, and confirmation. It identifies a bundle-level module effect, not the contribution of each internal mechanism. E2 isolates source authority at the input boundary, yet confirmation and blocking create an end-to-end action floor.

Fourth, auto_compiled is one policy compiler, not a complete model of human authorization. The stress regimes approximate common policy errors but do not measure their prevalence in deployed systems. exact_gold is intentionally artificial and should not be read as a recommended configuration.

Fifth, the effect environment is isolated. This is necessary to prevent real email, payment, browser, code, or production actions, but it may omit latency, state, and recovery behavior found in live applications.

Sixth, only a prespecified subset of B200 survivors is extended toward 500. That conditional tail does not constitute a complete B500 panel and cannot prove saturation. Attack search is still one family of defense-aware optimization; another optimizer may find different failures.

Seventh, E6 uses a historically risk-enriched cohort in a single execution block, with 47/60 tasks overlapping E3. It observes activity in that selected block but cannot estimate deployment prevalence, benign utility, cross-date repeatability, or independent-sample replication. Its M3

factor estimates remain bundle-level and do not identify provenance as the causal component.

Eighth, failure handling is conservative but not interpretation-free. All response-bearing failures are terminal in ITT, whereas response-less transport failures can receive bounded explicit recovery. We report raw failures and superseded attempts so readers can assess that choice.

Ninth, historical ASK measures system confirmation-request incidence and terminates the trajectory. E7a adds paired in-memory approval/denial conditions but no model clarification turn, human participant, or backend state change. Its exact-policy control deliberately disagrees with the request's permitted wording, and both modules share a new wrapper. Permit differences therefore do not identify an improvement over a correctly compiled policy, human response quality, workload, task completion, or deployed security.

Native dynamic-environment validation also remains incomplete. E2 uses synthetic benchmark-domain scenarios rather than native AgentDojo execution. AgentDyn's open-ended tasks and helpful third-party instructions provide a relevant external-validity challenge [23], but our native loader and fixture checks have not produced model-evaluation results. They are not included as an additional benchmark or robustness finding.

Finally, this paper does not include an independent blind set. It also does not claim first, only, or SOTA status. Its external-validity claims are limited to the models, benchmarks, policy compiler, stress regimes, and attack budgets actually evaluated. The benign-task review is post-outcome and has no independent reviewer-agreement calibration. It distinguishes authority and execution evidence but does not adjudicate every false block or recover redacted arguments.

5.6 Practical implications

Four practical recommendations follow. First, agent-security benchmarks should publish the fields visible to the online Guard and keep evaluator-only answers outside that projection. Second, runtime defenses should be evaluated factorially against a simpler policy package so prompt and module effects are separately identifiable; the internal modules require further ablations before individual attribution. Third, source-only counterfactuals should be paired with both deterministic Guard replay and end-to-end execution, rather than treating either as a proxy for the other. Fourth, security reports should include benign completion, system confirmation/blocking incidence, failures, latency, and attack budget alongside unsafe-effect rate.

The DeepSeek authorization-regime results now tie these recommendations to observed effects: exact and stressed policies materially changed completion, blocking, failure, and latency while observed unsafe effects remained near zero. E6 additionally shows why an active no-defense control should accompany floor-limited defended cells. Both Gemini attempts closed with incomplete diagnostic subsets and cannot alter or broaden the DeepSeek findings.

6 Conclusion

This study evaluates authorization semantics rather than assuming that an enabled runtime module establishes effective protection. An implementation audit found that the historical oracle monitor required complete argument dictionary equality despite partial target annotations. Consequently, the historical completion collapse and benchmark reversal cannot establish an intrinsic cost of precise authorization. Those records remain historical observations; the corrected target-scoped experiment is reported separately.

The 900-assignment corrected study holds the prompt ordinary across policy and full modules. AgentDojo exact-target completion is 13/30 and 11/30, compared with 2/30 in both compiled-policy conditions. M3-v2 exact-target completion is 14/30 and 16/30, compared with 16/30 and 17/30. The latter differences have intervals spanning zero, so the new study does not establish a benchmark-intrinsic reversal. The oracle supplies answer-derived scope to the Guard and is not a deployable authorization source. Its improved AgentDojo completion does not demonstrate non-oracle usability. All 490 attack assignments have zero observed security events, but the absence of an unguarded control makes this study insufficient for effectiveness claims.

The separate 480-assignment calibration provides a contemporaneous ordinary-prompt control. AgentDojo benign-tool completion falls from 17/30 without the research Guard to 2/30 with either policy or full modules. The paired decrease is 50 percentage points, with a 95% interval of 26.80 to 66.83 points. The security difference, 3/30 versus 0/30, has a paired risk-difference interval of -25.62 to $+3.10$ points and does not establish a reduction. M3-v2 controls already have no security events. These results identify a utility cost in the tested automatic authorization, not full-module superiority. Missing tool permissions are an observed cause category; they are not proof that every withheld permission should be granted. The subsequent fixed 60-task review retains seven trusted application declarations, identifies thirteen additional direct-target rules and ten M3-v2 tasks requiring unavailable independent confirmation, and exposes bounded generic-compiler coverage on AgentDojo. No new declared-contract violation was established. The cause of three mock-API execution/completion mismatches remains unresolved in redacted records; successful execution is not sufficient for task completion.

Sixteen synthetic Pro and V4.1 Flash executions show bounded component behavior: full modules deny private data sent to a restricted target, request clarification when classification is absent, and permit the tested public and archival flows. These controls neither cover arbitrary information transformations nor establish protection on natural tasks. The earlier source-authority replay likewise remains distinct from its end-to-end runs and from permission-only confirmation diagnostics.

Evaluation must retain proposals, Guard decisions, boundary rejection, simulated execution, task completion, operational failure, and unknown outcomes as separate observations. AgentDojo native attack judgments and M3-v2 simulated unauthorized effects are not interchangeable. The calibration has two missing projection receipts and four missing structured safety receipts; these gaps are not retrospectively filled. Runtime total latency is available for 476/480 assignments, but early termination and unequal call paths prevent interpreting shorter latency as a Guard computation gain.

Historical Public, factorial, calibration, and adaptive observations remain bounded by their original labels and configurations. In particular, the 12-task B200-survivor tail is not a complete B500 panel or evidence of saturation. Cohort overlap, one execution period, an explicitly adapted VIGIL configuration, sparse events, and deferred Gemini constrain external validity. Independent-model and dynamic-environment model studies remain unqualified rather than completed results. The defensible contribution is the corrected operationalization and empirical account of authorization burden, together with transparent limits on what runtime defense evidence can establish.

Declarations

Competing interests

The corresponding author must confirm the competing-interests declaration with all authors before submission.

Funding

The corresponding author must provide the funder name, grant number, and sponsor role, or confirm that the research received no specific grant from funding agencies in the public, commercial, or not-for-profit sectors.

Data and code availability

The implementation, frozen lean experiment plan, analysis code, aggregate tables, and editable figures are maintained at https://github.com/Fischl0527/RedTeam_LLM_Security. The repository is private during manuscript preparation. A public archival release with an immutable version identifier will be deposited before publication. Credentials and secrets are excluded from the release. Any restrictions on provider-derived compact raw records will be stated explicitly in the archival record.

Declaration of generative AI and AI-assisted technologies in the manuscript preparation process

During preparation of this work, the authors used OpenAI Codex for software editing, statistical-script review, figure-generation support, and language revision. An earlier DeepSeek-generated project-planning note supplied by the project owner was consulted during study scoping. Author review and approval of the resulting material must be completed before submission; final responsibility for the analysis, interpretation, citations, and manuscript content rests with the authors. DeepSeek and Gemini API outputs reported in the experiments are evaluated research data; they were not used to generate outcome labels or statistical conclusions.

Ethics and safety

The study involved no human participants and collected no personal data. Tool effects were evaluated in isolated benchmark state. Real email, payment, browser, code-execution, production-API, and provider-managed tool operations were disabled. The authors must confirm any institutional review or exemption requirement before submission.

Author contributions

Author order and CRediT roles must be approved by every author before submission.

References

[1] DEBENEDETTI E, ZHANG J, BALUNOVIC M, et al. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents[J/OL]. Advances in Neural Information Processing Systems, 2024, 37:82895-82920. https://proceedings.neurips.cc/paper_files/paper/2024/hash/97091a5177d8dc64b1da8bf3e1f6fb54-Abstract-Datasets_and_Benchmarks_Track.html. DOI: 10.52202/079017-2636.

[2] ZHAN Q, LIANG Z, YING Z, et al. InjecAgent: Benchmarking indirect prompt injections in tool-integrated large language model agents[C/OL]//KU L W, MARTINS A, SRIKUMAR V. Findings of the Association for Computational Linguistics: ACL 2024. Bangkok, Thailand: Association for Computational Linguistics, 2024: 10471-10506. https://aclanthology.org/2024.findings-acl.624/. DOI: 10.18653/v1/2024.findings-acl.624.

[3] LIN J, ZHOU Z, ZHENG Z, et al. VIGIL: Defending LLM agents against tool-stream injection via verify-before-commit[C/OL]//LIAKATA M, MOREIRA V P, ZHANG J, et al. Proceedings of the 64th Annual Meeting of the Association for Computational Linguistics

(Volume 1: Long Papers). San Diego, California, United States: Association for Computational Linguistics, 2026: 9764-9785. https://aclanthology.org/2026.acl-long.443/. DOI: 10.18653/v1/2026.acl-long.443.

[4] LI H, LIU X, CHIU H C, et al. DRIFT: Dynamic rule-based defense with injection isolation for securing LLM agents[J/OL]. Advances in Neural Information Processing Systems, 2025, 38:83262-83290. https://proceedings.neurips.cc/paper_files/paper/2025/hash/77f3b26c7907aa27b207df9b9d43f29a-Abstract-Conference.html. DOI: 10.52202/085713-2791.

[5] JIA F, WU T, QIN X, et al. The task shield: Enforcing task alignment to defend against indirect prompt injection in LLM agents[C/OL]//CHE W, NABENDE J, SHUTOVA E, et al. Proceedings of the 63rd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers). Vienna, Austria: Association for Computational Linguistics, 2025: 29680-29697. https://aclanthology.org/2025.acl-long.1435/. DOI: 10.18653/v1/2025.acl-long.1435.

[6] WANG H, POSKITT C M, SUN J. AgentSpec: Customizable runtime enforcement for safe and reliable LLM agents[C/OL]//2026 IEEE/ACM 48th International Conference on Software Engineering (ICSE). 2026: 2938-2950. https://conf.researchr.org/details/icse-2026/icse-2026-research-track/29/AgentSpec-Customizable-Runtime-Enforcement-for-Safe-and-Reliable-LLM-Agents. DOI: 10.1145/3744916.3764546.

[7] AN H, ZHANG J, DU T, et al. IPIGuard: A novel tool dependency graph-based defense against indirect prompt injection in LLM agents[C/OL]//CHRISTODOULOPOULOS C, CHAKRABORTY T, ROSE C, et al. Proceedings of the 2025 Conference on Empirical Methods in Natural Language Processing. Suzhou, China: Association for Computational Linguistics, 2025: 1023-1039. https://aclanthology.org/2025.emnlp-main.53/. DOI: 10.18653/v1/2025.emnlp-main.53.

[8] TSAI L, BAGDASARYAN E. Contextual agent security: A policy for every purpose [C/OL]//Proceedings of the Workshop on Hot Topics in Operating Systems. 2025: 8-17. https://research.google/pubs/context-is-key-for-agent-security/. DOI: 10.1145/3713082.3730378.

[9] SHI T, HE J, WANG Z, et al. Progent: Securing AI agents with privilege control[EB/OL]. 2025. https://arxiv.org/abs/2504.11703. DOI: 10.48550/arXiv.2504.11703.

[10] DEBENEDETTI E, SHUMAILOV I, FAN T, et al. Defeating prompt injections by design [EB/OL]. 2025. https://arxiv.org/abs/2503.18813. DOI: 10.48550/arXiv.2503.18813.

[11] WENG S, FENG Y, ZHANG J, et al. ARGUS: Defending LLM agents against context-aware prompt injection[EB/OL]. 2026. https://arxiv.org/abs/2605.03378. DOI: 10.48550/arXiv.2605.03378.

[12] WANG P, LI Y, TIAN Y. Aligning provenance with authorization: A dual-graph defense for LLM agents[EB/OL]. 2026. https://arxiv.org/abs/2605.26497. DOI: 10.48550/arXiv.2605.26497.

[13] LIAO J. Auditing provenance sensitivity in LLM agent action selection[EB/OL]. 2026. https://arxiv.org/abs/2607.20827. DOI: 10.48550/arXiv.2607.20827.

[14] ZHANG Y, ZHAO X, LIU S, et al. FAVA: Formal authorization for verified agents with evidence-backed permission graphs[EB/OL]. 2026. https://arxiv.org/abs/2607.27267. DOI: 10.48550/arXiv.2607.27267.

[15] CHEN S, PIET J, SITAWARIN C, et al. StruQ: Defending against prompt injection with structured queries[C/OL]//34th USENIX Security Symposium (USENIX Security 25). 2025: 2383-2400. https://www.usenix.org/conference/usenixsecurity25/presentation/chen-sizhe.

[16] HINES K, LOPEZ G, HALL M, et al. Defending against indirect prompt injection attacks with spotlighting[EB/OL]. 2024. https://arxiv.org/abs/2403.14720. DOI: 10.48550/arXiv.2403.14720.

[17] WALLACE E, XIAO K, LEIKE R, et al. The instruction hierarchy: Training LLMs to prioritize privileged instructions[EB/OL]. 2024. https://arxiv.org/abs/2404.13208. DOI: 10.48550/arXiv.2404.13208.

[18] CHEN Y, LI H, SUI Y, et al. Can indirect prompt injection attacks be detected and removed?[C/OL]//CHE W, NABENDE J, SHUTOVA E, et al. Proceedings of the 63rd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers). Vienna, Austria: Association for Computational Linguistics, 2025: 18189-18206. https://aclanthology.org/2025.acl-long.890/. DOI: 10.18653/v1/2025.acl-long.890.

[19] NASR M, CARLINI N, SITAWARIN C, et al. The attacker moves second: Stronger adaptive attacks bypass defenses against LLM jailbreaks and prompt injections[EB/OL]. 2025. https://arxiv.org/abs/2510.09023. DOI: 10.48550/arXiv.2510.09023.

[20] GONG G, DENG Z. PlanGuard: Defending agents against indirect prompt injection via planning-based consistency verification[EB/OL]. 2026. https://arxiv.org/abs/2604.10134. DOI: 10.48550/arXiv.2604.10134.

[21] ZHANG H, HUANG J, MEI K, et al. Agent security bench (ASB): Formalizing and benchmarking attacks and defenses in LLM-based agents[C/OL]//YUE Y, GARG A, PENG N, et al. International Conference on Learning Representations: volume 2025. 2025: 35331-35366. https://proceedings.iclr.cc/paper_files/paper/2025/file/5750f91d8fb9d5c02bd8ad2c3b44456b-Paper-Conference.pdf.

[22] GENG R, YIN C, WANG Y, et al. PIArena: A platform for prompt injection evaluation [C/OL]//Proceedings of the 64th Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers). Association for Computational Linguistics, 2026: 33170-33192. https://aclanthology.org/2026.acl-long.1533/. DOI: 10.18653/v1/2026.acl-long.1533.

[23] LI H, WEN R, SHI S, et al. AgentDyn: Are your agent security defenses deployable in real-world dynamic environments?[EB/OL]. 2026. https://arxiv.org/abs/2602.03117v3. DOI: 10.48550/arXiv.2602.03117.

[24] SEHWAG U M, SHAN Z, LIU H, et al. ASPI: Seeking ambiguity clarification amplifies prompt injection vulnerability in LLM agents[EB/OL]. 2026. https://arxiv.org/abs/2605.17324v1. DOI: 10.48550/arXiv.2605.17324.